**EWB Cybersecurity Assessment 01**

**Name:** Sayyad Sarah Yohan
**Batch:** 1

**Task A: Secure a student account**

| Risk | Asset | CIA impact | Control | Limitation |
|---|---|---|---|---|
| Same short pw for mail and portal | mail account plus portal account | Confidentiality and integrity. If one gets leaked, hacker can get into both and change stuff | Different long pw for each, keep them in a pw manager | Mira has to remember the one master pw, and if that gets hacked everything is gone |
| Approving sign in prompts she didn't start | her account | Confidentiality and integrity. Hacker gets in as soon as she taps approve | Only approve if she was the one logging in, report the weird ones | She can still get fooled by a fake prompt that looks normal |
| Not updating laptop | laptop + files | All three (C, I, A). Old bugs let in virus or ransomware | Turn on auto update | Doesn't help with brand new bugs, and she still has to restart |
| Only 1 copy of project | project files | Availability. Laptop dies or gets stolen means the work gone | Keep another copy on cloud and pendrive | Cloud can sync a delete too, and she has to check the backup works |
| Friend uses laptop on Mira's logged in account | her account plus files | Confidentiality and integrity. Friend can read or change things | Lock screen and make a separate guest account for the friend | She has to remember to lock it, and friend can still peek if it's open |

**Top 3 to do first:**

1. Unique pw + MFA, because the same pw everywhere is the biggest problem. One leak and 2 accounts are gone, and it's quick to fix.
2. Stop approving random prompts, because MFA is useless if she just taps yes on everything.

3. Stop friend using her acc, because someone already has access right now so fixing it fast matters.

Updates and backup are important too but come after, since they're less likely to cause a problem right now.

**A3:** Authentication is proving it's really you. On the portal that's Mira typing her pw and the MFA code. Authorisation is what you're allowed to do once you're in. Mira can see her own courses and submit work, but she can't open the teacher's marks page or other students' marks. So one is "who are you" and the other is "what can you do".

**Task B: Suspicious message**

**B1: Warning signs**

| **Phrase** | **Why it's suspicious** |
|---|---|
| "FINAL WARNING - scholarship expires in 20 minutes" | Fake rush. Scammers do this so you don't think |
| awards@campus-awards | College uses campus, this one is a different name that looks kinda similar |
| Reply-To help@personal-awards | Replies go to a 3rd different place, not the sender and not the college |
| "enter your college password and OTP" | Nobody real asks for pw and OTP together, OTP is secret |
| "Do not contact the college office" | They don't want you to check with anyone, which is a scam move |

**B2: Safe way to check**

1. Don't click the link, don't reply.
2. Get the college number or portal myself from the official site or the ID card, not from the msg.
3. Call them or log in directly and ask if there's any scholarship.
4. HTTPS just means the connection is locked, it doesn't mean the site is honest, scammers can get it too. Display name can be faked as well, so neither proves the msg is real.

**B3: If Sarah already put her pw and OTP**

1. Change the pw straight away from the official portal, on a safe device.
2. Log out of all devices and check the MFA and recovery settings.

3. Tell the college IT using the official contact.
4. Change the pw anywhere else she used the same one.
5. Keep checking for weird sign in alerts, and check the mail settings like forwarding in case they changed it.
6. If she sent an ID photo, tell the college that too.

**B4:** From just the msg I can't tell if the sender really owns those addresses, or if the college started using a new system. It'd help to see the full mail headers and ask college IT if they use campus-awards.

**Task C: Sign-in alert**

**C1: Timeline**

1. **Seen:** 09:00-09:01 student07 logged in from the usual classroom IP (192.0.2.10), MFA approved. *My guess:* looks normal.
2. **Seen:** 10:14-10:16 two wrong pws, then success from a new IP (198.51.100.23). *My guess:* someone was trying pws or already had it.
3. **Seen:** 10:17-10:18 MFA denied, then approved from the same new IP. Student says they approved around 10:18 to stop the requests. *My guess:* prompt spam and they gave up and approved.
4. **Seen:** 10:20 session created from the new IP, and student says they didn't sign in after 09:05. *My guess:* a stranger might still be logged in.

**C2:**

- **Likely:** someone got the pw, spammed MFA, and the student approved by mistake.
- **Other possibility:** it was the student on a different network like mobile data and they forgot.

2 checks:

1. Check the device and location info of the 10:20 session and compare with the student's normal devices.
2. Ask the student if they were on another network, and see if other accs got tries from the same IP.

IP can't tell who the person is, so I'm not saying who did it.

**C3: What IT should do**

1. Save the logs, session info and MFA records first before changing anything.

2. Kill the active sessions, reset the pw and check the MFA devices.
3. Check if the account sent any msgs or changed settings, and tell the student not to approve prompts they didn't start.

**C4: Summary**

On 18 Oct 2026 student07's account had two wrong pws then a success from 198.51.100.23 instead of the usual classroom IP, then MFA approved and a session at 10:20. Student says they didn't log in and approved a prompt to stop the requests. Not sure if the pw was stolen or the student was on a new network. Priority is high because a session is active. Next step is IT saves logs, kills the session and resets the pw.

**Task D: AI answer review**

**D1:**

| **AI said** | **Fix** |
|---|---|
| "safe because it uses HTTPS" | HTTPS only locks the connection, doesn't prove the sender is honest (CISA says same) |
| "logs prove the person on 198.51.100.23 stole the pw" | Logs only show what happened from an IP, can't prove who or that it was stolen. It's suspicious, not proof |
| "MFA prevents every compromise" | It helps a lot but not always, in Task C the student approved a prompt by mistake |
| "Delete the suspicious logs" | Logs are evidence, deleting them ruins the investigation |
| "send the student's pw to support" | Never share pws, real support doesn't ask. Reset it instead |

**D2: Better prompt**

"Look only at the fake evidence I paste below. Tell me which things are facts from the evidence and which are just your guesses. Don't ask me for any pw, OTP or personal info. Say where you're not sure and what extra proof would help. Give safe next steps and don't say anything the evidence doesn't show. [paste fake evidence]"

**D3: My advice**

Sarah, if a msg asks for your pw, OTP or ID, don't trust it, even if it looks official or has HTTPS. HTTPS only means the connection is locked, not that the sender is honest. Check the sender and contact the college using a number or portal you found yourself. Never give your pw or OTP to anyone, even support. If you approved a prompt you didn't start, tell IT fast so they can end sessions and reset your pw. Don't delete logs, keep them as evidence. MFA makes

hacking harder but doesn't stop everything, so be careful with prompts. Use different pws, update your devices and keep backups.

**D4: AI declaration + references**

*AI use:* [write what you really did, like "used Claude to help with drafting and I checked and edited it myself" or "not used"]

*References:*


1. CISA Secure Our World, https://www.cisa.gov/secure-our-world (account and phishing basics, used in A and B)
2. NIST AI 600-1, https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf (about checking AI answers for mistakes, used in D)